PUBLICATION

Privacy by Design: Building Clinical AI Without Compromising Patient Data

Our approach to training on de-identified data, HIPAA/GDPR compliance, and why proprietary models are inherently more secure than generic LLM wrappers.

Published:	May 2025
Document ID:	PUB-2025-005
Classification:	Public
Author:	ClinixSummary Research Team

This document is provided for informational purposes only. ClinixSummary is a product of GATMEDI. The information contained herein is proprietary and confidential. Reproduction or distribution without prior written consent is prohibited. For the latest version, visit clinixsummary.ai.

© 2025 GATMEDI. All rights reserved. | contact@clinixsummary.ai

1. Executive Summary

The rise of generative AI in healthcare has created a tension: the most capable models require vast training data, yet clinical data is among the most sensitive information in existence. Many AI documentation products address this tension poorly — by sending patient data to third-party large language models with unclear data handling practices. ClinixSummary takes a fundamentally different approach: privacy by design.

2. The Problem with Generic LLM Wrappers

A significant number of AI clinical documentation products are architecturally simple: they transcribe clinical audio, send the transcript to a third-party LLM (such as GPT-4 or Claude) via API, and return the formatted response. This approach has serious privacy implications:

- Patient data leaves the healthcare organisation's control and enters third-party infrastructure.
- Data retention policies are determined by the LLM provider, not the healthcare organisation.
- Training data contamination — some providers may use API inputs for model improvement unless explicitly opted out.
- Regulatory grey areas — BAA coverage for third-party LLM APIs varies and may not cover all data processing activities.
- No specialty-specific optimisation — general-purpose models lack clinical domain depth.

3. ClinixSummary's Privacy Architecture

3.1 Proprietary Models

ClinixSummary uses proprietary clinical language models trained and hosted entirely within our controlled infrastructure. No patient data is ever sent to third-party AI providers. This eliminates the most significant privacy risk in AI clinical documentation.

3.2 De-Identified Training Data

All model training uses rigorously de-identified data compliant with HIPAA Safe Harbor and Expert Determination standards. Training data sources include licensed de-identified datasets, medical literature, clinical guidelines, and synthetic data validated by clinicians.

3.3 Ephemeral Audio Processing

Audio recordings are encrypted immediately upon capture, processed in secure memory, and deleted automatically after note generation. Maximum audio retention is 24 hours, after which cryptographic erasure ensures irrecoverable deletion.

3.4 Data Sovereignty

© 2025 GATMEDI. All rights reserved. | contact@clinixsummary.ai

ClinixSummary offers geographic data residency (US, EU, UK, AU) ensuring that patient data never leaves the jurisdiction in which it was created. For enterprise customers, on-premises deployment is available.

4. Regulatory Compliance

Privacy by design translates directly to regulatory compliance:

- HIPAA — BAAs executed for all US customers. Full Administrative, Physical, and Technical Safeguards.
- GDPR — Data Processing Agreements, DPIAs, data subject rights, EU data residency.
- PIPEDA/PHIPA — Canadian privacy framework compliance.
- CCPA — California Consumer Privacy Act compliance.
- Australian Privacy Act — APPs compliance for Australian deployments.

5. Why Proprietary Models Are More Secure

Proprietary models provide security advantages beyond data handling:

- Reduced attack surface — no external API calls to intercept or compromise.
- Full control over model behaviour — no risk of prompt injection or jailbreaking affecting clinical outputs.
- Deterministic behaviour — proprietary models can be locked to specific versions, ensuring consistent behaviour.
- Auditable processing — every step of the pipeline is logged and auditable within ClinixSummary's infrastructure.

6. Conclusion

Privacy in clinical AI is not a feature — it is a design philosophy. ClinixSummary's proprietary model architecture ensures that patient data remains under the healthcare organisation's control at all times, with no reliance on third-party AI providers. This is the standard that healthcare AI should meet.

To discuss privacy architecture in detail or request a security review, contact: security@clinixsummary.ai

© 2025 GATMEDI. All rights reserved. | contact@clinixsummary.ai